

Laporan Penilaian Kerentanan (Vulnerability Assessment)

Nama Proyek:	Portofolio Uji Coba Keamanan SQA
Aplikasi / URL Target:	http://localhost:3000 (OWASP Juice Shop)
Tool Pemindai:	OWASP ZAP (Zed Attack Proxy)
Dilaporkan Oleh:	Umar Abdul Aziz
Tanggal Pemindaian:	4 Mei 2025

Ringkasan Eksekutif

Pemindaian keamanan otomatis telah dilakukan terhadap aplikasi web target menggunakan OWASP ZAP. Hasil pemindaian mengidentifikasi **13 kategori temuan keamanan** yang terdiri dari berbagai tingkat risiko. Temuan-temuan ini mencakup kerentanan konfigurasi keamanan, header keamanan yang hilang, potensi kebocoran informasi, dan kerentanan dalam komponen aplikasi.

Distribusi Temuan Berdasarkan Tingkat Risiko:

- **Medium (Sedang):** 6 temuan
- **Low (Rendah):** 4 temuan
- **Informational (Informasi):** 3 temuan

Laporan ini memberikan rincian untuk setiap temuan beserta rekomendasi mitigasi yang diperlukan untuk meningkatkan postur keamanan aplikasi.

Temuan Kerentanan Berdasarkan Tingkat Risiko

A. Kerentanan Tingkat MEDIUM (Sedang)

1. CSP: Failure to Define Directive with No Fallback (2)

- **Deskripsi:** Content Security Policy (CSP) tidak mendefinisikan direktif tertentu dan tidak memiliki fallback yang memadai. Terdapat 2 instance dari masalah ini.
- **Dampak:** Membuka peluang serangan XSS (Cross-Site Scripting) karena kebijakan keamanan konten tidak dikonfigurasi dengan benar.
- **Rekomendasi:**
 - Implementasikan CSP yang lengkap dengan semua direktif yang diperlukan
 - Tambahkan direktif fallback seperti default-src
 - Gunakan Content-Security-Policy header dengan konfigurasi yang ketat

2. Content Security Policy (CSP) Header Not Set (579)

- **Deskripsi:** Header CSP tidak ditetapkan pada 579 response. Ini merupakan temuan dengan jumlah instance terbanyak.
- **Dampak:** Aplikasi sangat rentan terhadap serangan XSS, clickjacking, dan injeksi konten berbahaya lainnya.
- **Rekomendasi:**
 - Implementasikan CSP header pada seluruh response aplikasi
 - Mulai dengan kebijakan yang ketat: Content-Security-Policy: default-src 'self'
 - Sesuaikan kebijakan berdasarkan kebutuhan aplikasi secara bertahap

3. Cross-Domain Misconfiguration (577)

- **Deskripsi:** Konfigurasi cross-domain yang tidak tepat ditemukan pada 577 instance.
- **Dampak:** Dapat memungkinkan akses tidak sah dari domain lain, berpotensi menyebabkan kebocoran data sensitif atau serangan CSRF.
- **Rekomendasi:**
 - Review dan konfigurasikan CORS (Cross-Origin Resource Sharing) dengan benar
 - Batasi Access-Control-Allow-Origin hanya untuk domain yang dipercaya
 - Hindari penggunaan wildcard * dalam production

4. Missing Anti-clickjacking Header (31)

- **Deskripsi:** Header X-Frame-Options atau CSP frame-ancestors tidak ditemukan pada 31 response.
- **Dampak:** Aplikasi dapat di-embed dalam iframe oleh situs jahat untuk melakukan clickjacking attack.
- **Rekomendasi:**
 - Tambahkan header X-Frame-Options: DENY atau X-Frame-Options: SAMEORIGIN
 - Atau gunakan CSP dengan direktif frame-ancestors 'self'

5. Cross-Domain JavaScript Source File Inclusion (1078)

- **Deskripsi:** Aplikasi memuat file JavaScript dari domain eksternal pada 1078 instance.

- **Dampak:** Jika sumber eksternal dikompromikan, kode berbahaya dapat diinjeksikan ke aplikasi. Supply chain attack menjadi risiko nyata.
- **Rekomendasi:**
 - Host semua file JavaScript secara lokal jika memungkinkan
 - Jika harus menggunakan CDN eksternal, implementasikan Subresource Integrity (SRI)
 - Gunakan CSP untuk membatasi sumber JavaScript yang diizinkan

6. Timestamp Disclosure - Unix (1630)

- **Deskripsi:** Aplikasi mengekspos Unix timestamp pada 1630 lokasi.
- **Dampak:** Informasi timing dapat digunakan untuk reconnaissance, mengidentifikasi pola aktivitas, atau membantu serangan timing-based.
- **Rekomendasi:**
 - Evaluasi apakah timestamp perlu diekspos ke client
 - Pertimbangkan penggunaan format waktu relatif atau yang kurang spesifik
 - Implementasikan kontrol akses untuk data sensitif yang berhubungan dengan waktu

B. Kerentanan Tingkat LOW (Rendah)

7. Session ID in URL Rewrite (105)

- **Deskripsi:** Session ID ditemukan dalam URL rewrite pada 105 instance.
- **Dampak:** Session ID dapat tercatat dalam log server, browser history, atau referrer headers, meningkatkan risiko session hijacking.
- **Rekomendasi:**
 - Gunakan cookie dengan flag HttpOnly dan Secure untuk session management
 - Hindari menyertakan session ID dalam URL
 - Implementasikan session regeneration setelah login

8. Vulnerable JS Library

- **Deskripsi:** Aplikasi menggunakan library JavaScript dengan kerentanan yang diketahui.
- **Dampak:** Kerentanan pada library dapat dieksploitasi untuk berbagai serangan tergantung jenis vulnerability.
- **Rekomendasi:**
 - Identifikasi dan update library yang rentan ke versi terbaru
 - Gunakan tools seperti npm audit, Snyk, atau OWASP Dependency-Check
 - Implementasikan proses monitoring berkelanjutan untuk dependencies

9. Private IP Disclosure

- **Deskripsi:** Alamat IP privat terekspos dalam response aplikasi.
- **Dampak:** Memberikan informasi tentang topologi jaringan internal yang dapat digunakan untuk reconnaissance.
- **Rekomendasi:**
 - Review response aplikasi dan hilangkan informasi IP internal
 - Konfigurasi proxy/load balancer untuk menghilangkan header yang mengandung IP internal

- Implementasikan proper error handling yang tidak mengekspos informasi sistem

10. X-Content-Type-Options Header Missing (104)

- **Deskripsi:** Header X-Content-Type-Options tidak ditemukan pada 104 response.
- **Dampak:** Browser dapat melakukan MIME-sniffing dan menginterpretasikan konten dengan cara yang tidak diinginkan, berpotensi menyebabkan XSS.
- **Rekomendasi:**
 - Tambahkan header X-Content-Type-Options: nosniff pada semua response
 - Pastikan Content-Type header selalu ditetapkan dengan benar

C. Temuan Tingkat INFORMATIONAL (Informasi)

11. Information Disclosure - Suspicious Comments (4)

- **Deskripsi:** Komentar yang mencurigakan ditemukan dalam kode sumber pada 4 lokasi.
- **Dampak:** Komentar dapat mengandung informasi sensitif seperti kredensial, struktur database, atau informasi debugging yang membantu penyerang.
- **Rekomendasi:**
 - Review dan hapus komentar yang mengandung informasi sensitif
 - Implementasikan proses build yang menghapus komentar dari production code
 - Lakukan code review untuk memastikan tidak ada informasi sensitif dalam komentar

12. Modern Web Application (540)

- **Deskripsi:** Aplikasi terdeteksi sebagai modern web application pada 540 instance.
- **Dampak:** Ini adalah temuan informational yang menunjukkan karakteristik aplikasi modern. Tidak ada dampak keamanan langsung.
- **Rekomendasi:** Tidak ada tindakan khusus diperlukan. Pastikan best practices untuk modern web application diterapkan.

13. Retrieved from Cache (81)

- **Deskripsi:** 81 resource diambil dari cache.
- **Dampak:** Temuan informational tentang perilaku caching. Perlu dipastikan bahwa data sensitif tidak di-cache secara tidak tepat.
- **Rekomendasi:**
 - Review konfigurasi caching untuk memastikan data sensitif tidak di-cache
 - Gunakan header Cache-Control: no-store untuk response yang mengandung data sensitif
 - Implementasikan Cache-Control: private untuk konten yang spesifik per-user

Prioritas Remediasi

Prioritas Tinggi (Segera):

1. Content Security Policy Header Not Set (579 instances)
2. Cross-Domain JavaScript Source File Inclusion (1078 instances)
3. Cross-Domain Misconfiguration (577 instances)

Prioritas Sedang (1-2 Minggu):

4. CSP: Failure to Define Directive with No Fallback
5. Missing Anti-clickjacking Header
6. Vulnerable JS Library
7. Session ID in URL Rewrite

Prioritas Rendah (Maintenance):

8. Timestamp Disclosure
9. X-Content-Type-Options Header Missing
10. Private IP Disclosure
11. Information Disclosure - Suspicious Comments

Rekomendasi Umum

1. Implementasi Security Headers Secara Komprehensif:

- Content-Security-Policy
- X-Frame-Options
- X-Content-Type-Options
- Strict-Transport-Security
- X-XSS-Protection (legacy support)

2. Dependency Management:

- Implementasikan proses regular update untuk library dan dependencies
- Gunakan automated tools untuk monitoring kerentanan

3. Secure Development Practices:

- Lakukan security code review regular
- Implementasikan secure coding guidelines
- Lakukan security testing sebagai bagian dari CI/CD pipeline

4. Configuration Management:

- Review dan harden konfigurasi web server dan application server
- Implementasikan principle of least privilege
- Hapus atau disable fitur yang tidak digunakan

5. Monitoring dan Logging:

- Implementasikan security monitoring untuk mendeteksi eksploitasi
- Log semua security events dengan proper alerting

Kesimpulan

Pemindaian mengidentifikasi beberapa area yang memerlukan perbaikan untuk meningkatkan postur keamanan aplikasi. Sebagian besar temuan terkait dengan konfigurasi security headers yang hilang atau tidak lengkap, yang relatif mudah untuk diperbaiki dengan dampak positif yang signifikan terhadap keamanan aplikasi.

Prioritas utama adalah implementasi CSP yang komprehensif dan penanganan cross-domain configuration yang tepat. Dengan mengatasi temuan-temuan ini secara sistematis berdasarkan prioritas, risiko keamanan aplikasi dapat dikurangi secara signifikan.

Catatan: Laporan ini dihasilkan dari automated scanning. Disarankan untuk melakukan manual security testing dan penetration testing untuk mengidentifikasi kerentanan yang mungkin tidak terdeteksi oleh automated tools.